CYBERSECURITY – INTRODUCTION AND FUNDAMENTAL CONCEPTS

Reiner Creutzburg

SRH Berlin, University of Applied Sciences, School of Technology, Sonnenallee 221c,D-12059 Berlin, Germany

reiner.creutzburg@gmail.com

Kadir Has University, Sept. 15, 2026

DEFINING CYBERSPACE AND CYBERSECURITY

Definition of **cyberspace** as stated in the Nation Research Council's publication *At the Nexus of Cybersecurity and Public Policy:*

"**Cyberspace** consists of artifacts based on or dependent on computer and communications technology; the information that these artifacts use, store, handle, or process; and the interconnections among these various elements."

DEFINING CYBERSPACE AND CYBERSECURITY

Definition of **cybersecurity** as provided in ITU-T

> "**Cybersecurity** is the collection of tools, policies, security concepts, security safeguards, guidelines, risk management approaches, actions, training, best practices, assurance and technologies that are used to protect the cyberspace environment and organization and user's assets. Organization and user's assets include connected computing devices, personnel, infrastructure, applications, services, telecommunications systems, and the totality of transmitted and/or stored information in the cyberspace environment. Cybersecurity strives to ensure the attainment and maintenance of the security properties of the organization and user's assets against relevant security risks in the cyberspace environment. The general security objectives comprise the following: availability, integrity, which may include authenticity and non-repudiation; and confidentiality."

Information Security

- Preservation of confidentiality, integrity, and availability of information
- Other properties such as authenticity, accountability non-repudiation, and reliability can also be involved

Network Security

- Protection of networks and their services from unauthorized modification, destruction, or disclosure and provision of assurance that the network performs its critical function correctly and that there are no harmful side effects

Risk

- A measure of the extent to which an entity is threatened by a potential circumstance or event and typically a function of

(1) the adverse impacts that would arise if the circumstance or event occurs

(2) the likelihood of occurrence

Asset

- Data contained in an information system; or a service provided by a system; or a system capability, such as processing power or communication bandwidth; or an item of system equipment (such as hardware, firmware, software, or documentation); or a facility that houses system operations and equipment

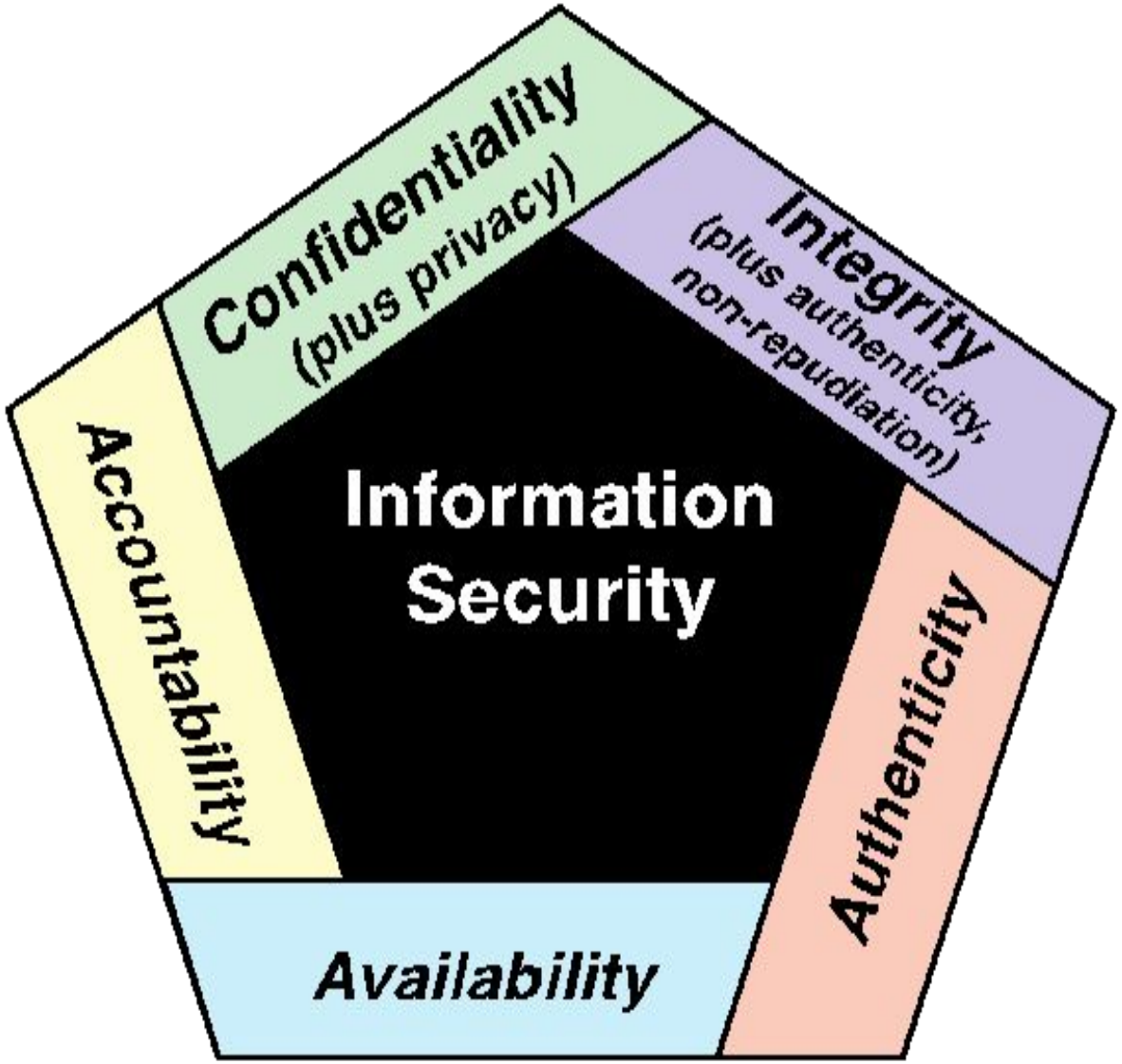


Figure 1.1 Essential Cybersecurity Objectives

CYBERSECURITY OBJECTIVES

Availability	Integrity	Authenticity	Non-repudiation	Confidentiality	Accountability
• The property of a system or a system resource being accessible or usable or operational upon demand, by an authorized system entity, according to performance specifications for the system	• The property that data has not been changed, destroyed, or lost in an unauthorized or accidental manner	• The property of being genuine and being able to verify that users are who they say they are and that each input arriving at the system came from a trusted source	• Assurance that the sender of information is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the information	• The property that data is not disclosed to system entities unless they have been authorized to know the data	• The property of a system or system resource ensuring that the actions of a system entity may be traced uniquely to that entity, which can then be held responsible for its actions

CYBERSECURITY DILEMMAS

Scale and complexity of cyberspace

- Is massive---cyberspace involves mobile devices, workstations, servers, massive data centers, cloud computing services, Internet of Things (IoT) deployments, and a wide variety of wired and wireless networks
- Variety of individuals and applications requiring some level of access to these resources is also huge
- The challenge to achieving cybersecurity constantly change as technologies advance, new applications of information technologies emerge, and societal norms evol

Nature of the threat

- Organizational assets in cyberspace are under constant and evolving threat from vandals, criminals, terrorists, hostile states, and other malevolent actors
- A variety of legitimate actors, including businesses and governments, are interested in collecting, analyzing, and storing information from and about individuals and organization, potentially creating security and privacy risks

User needs versus security implementation

- Users want technology with the most modern and powerful features, that is convenient to use, that offers anonymity in certain circumstances, and that is secure
- The simpler the system, and the more its individual elements are isolated from one another, the easier it is to implement effective security
- Users or groups within an organization that feel inconvenienced by security mechanisms will be tempted to find ways around those mechanisms or demand relaxation of the security requirements

Difficulty estimating costs and benefits

- It is difficult to estimate the total cost of cybersecurity breaches and, therefore, the benefits of security policies and mechanisms

Threat

- A potential for violation of security that exists when there is a circumstance, a capability, an action, or an event that could breach security and cause harm
- Basically, a threat is a possible danger that might exploit a vulnerability

Vulnerability

- A flaw or weakness in a system's design, implementation, or operation and management that could be exploited to violate the system's security policy

THE VALUE OF STANDARDS AND BEST PRACTICES DOCUMENTS

- A number of organizations, based on wide professional input, have developed best practices types of documents as well as standards for implementing and evaluating cybersecurity
  - National Institute of Standards and Technology (NIST)
  - ITU-T
  - International Organization for Standardization (ISO)
  - Internet Society (ISOC)
- A number of professional and industry groups have produced best practices documents and guidelines
  - The most important document is the Standard of Good Practice for Information Security, produced by the Information Security Forum (ISF)
    - This 300+ page document provides a wide range of best practices representing the consensus of industry and government organizations
  - Other respected organizations, including the Information Systems Audit and Control Association (ISACA) and the Payment Card Industry (PCI) have produced a number of similar documents

Source	Title	Date
Information Security Forum	The Standard of Good Practice for Information Security	2016
International Standards Organization	ISO 27002—Code of Practice for Information Security Controls	2013
NIST	Framework for Improving Critical Infrastructure Cybersecurity	2017
Center for Internet Security	The CIS Critical Security Controls for Effective Cyber Defense Version 7	2018
ISACA	COBIT 5 for Information Security	2012
PCI Security Standards Council	Data Security Standard v3.2—Requirements and Security Assessment Procedures	2016

Table 1.1
Important Best Practices and Standards Documents

THE STANDARD OF GOOD PRACTICE FOR INFORMATION SECURITY (SGP)

- The ISF is an independent, not-for-profit association of leading organizations from around the world
  - ISF members fund and cooperate in the development of a practical research program in information security
  - It is dedicated to investing, clarifying, and resolving key issues in cybersecurity, information security, and risk management and to developing best practice methodologies, processes, and solutions that meet the business needs of its members
- The most significant activity of the ISF is the ongoing development of the Standard of Good Practice for Information Security (SGP)
  - This document is a business-focused comprehensive guide to identifying and managing information security risks in organizations and their supply chains
  - The SGP is based on research projects and input from ISF members as well as analysis of the leading standards on cybersecurity, information security, and risk management

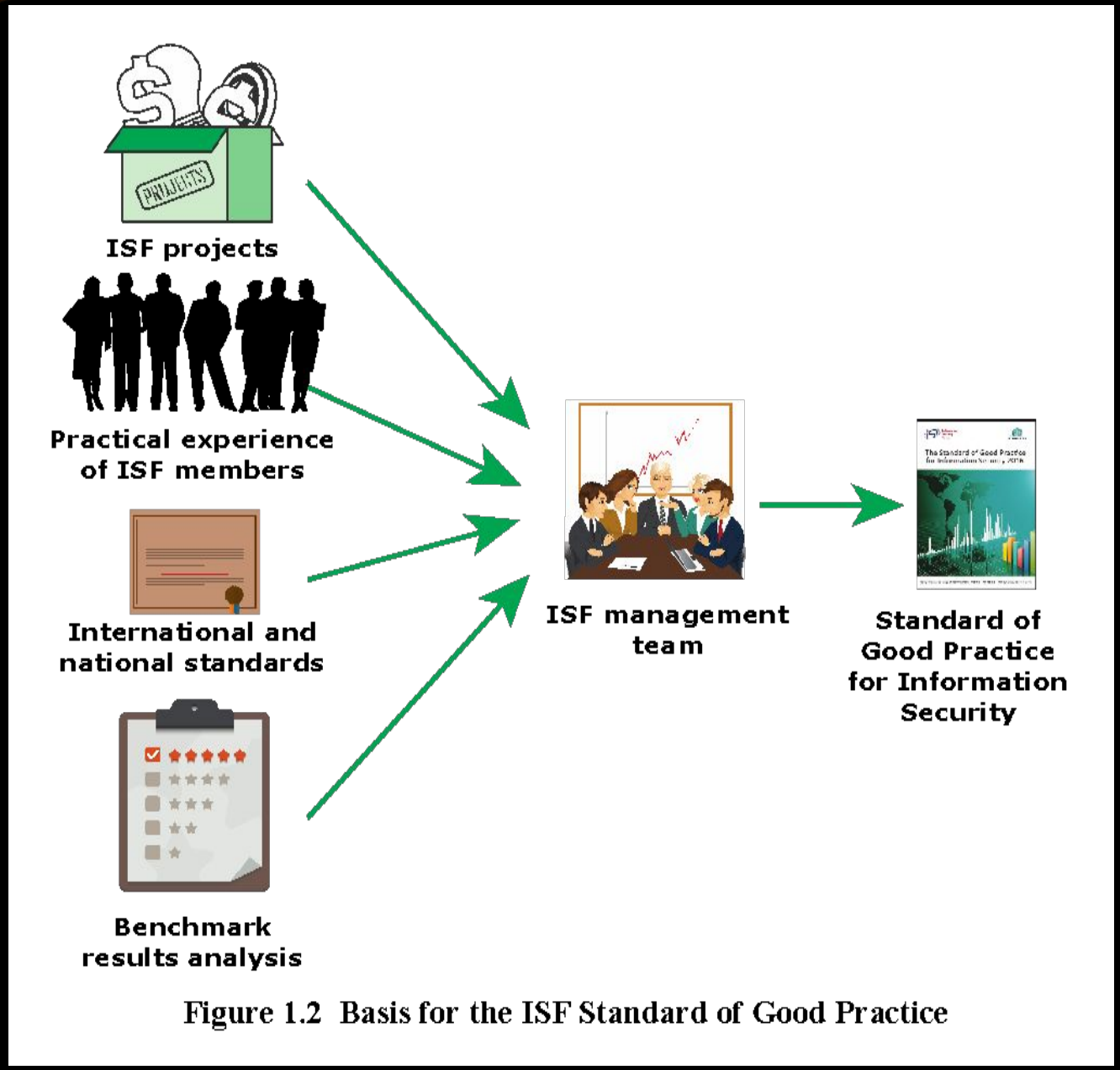


Figure 1.2 Basis for the ISF Standard of Good Practice

SECURITY POLICY

A set of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources

SGP IS OF INTEREST TO THE FOLLOWING INDIVIDUALS:

Chief information security officers (or equivalent)	Responsible for developing policy and implementing sound information security governance and information security assurance
Information security managers	Responsible for promoting or implementing an information security assurance program
Business managers	Responsible for ensuring that critical business applications, processes, and local environments on which an organization's success depends are effectively managed and controlled
IT managers and technical staff	Responsible for designing, planning, developing, deploying, and maintaining key business applications, information systems, or facilities
Internal and external auditors	Responsible for conducting security audits
IT service providers	Responsible for managing critical facilities (for example, computer installations, networks) on behalf of the organization
Procurement and vendor management teams	Responsible for defining appropriate information security requirements in contracts

Table 1.2

ISF Standard of Good Practice for Information Security: Categories and Areas

(Table is on pages 10-11 in the textbook)

SECURITY GOVERNANCE (SG) Security Governance Approach Security Governance Components INFORMATION RISK ASSESSMENT (IR) Information Risk Assessment Framework Information Risk Assessment Process SECURITY MANAGEMENT (SM) Security Policy Management Information Security Management PEOPLE MANAGEMENT (PM) Human Resource Security Security Awareness/Education INFORMATION MANAGEMENT (IM) Information Classification and Privacy Information Protection PHYSICAL ASSET MANAGEMENT (PA) Equipment Management Mobile Computing SYSTEM DEVELOPMENT (SD) System Development Management System Development Life Cycle BUSINESS APPLICATION MANAGEMENT (BA) Corporate Business Applications End User Developed Applications	SYSTEM ACCESS (SA) Access Management Customer Access SYSTEM MANAGEMENT (SY) System Configuration System Maintenance NETWORKS AND COMMUNICATIONS (NC) Network Management Electronic Communication SUPPLY CHAIN MANAGEMENT (SC) External Supplier Management Cloud Computing TECHNICAL SECURITY MANAGEMENT (TS) Security Solutions Cryptography THREAT AND INCIDENT MANAGEMENT (TM) Cybersecurity Resilience Security Incident Management LOCAL ENVIRONMENT MANAGEMENT (LE) Local Environments Physical and Environmental Security BUSINESS CONTINUITY (BC) Business Continuity Framework Business Continuity Process SECURITY MONITORING AND IMPROVEMENT (SI) Security Audit Security Performance

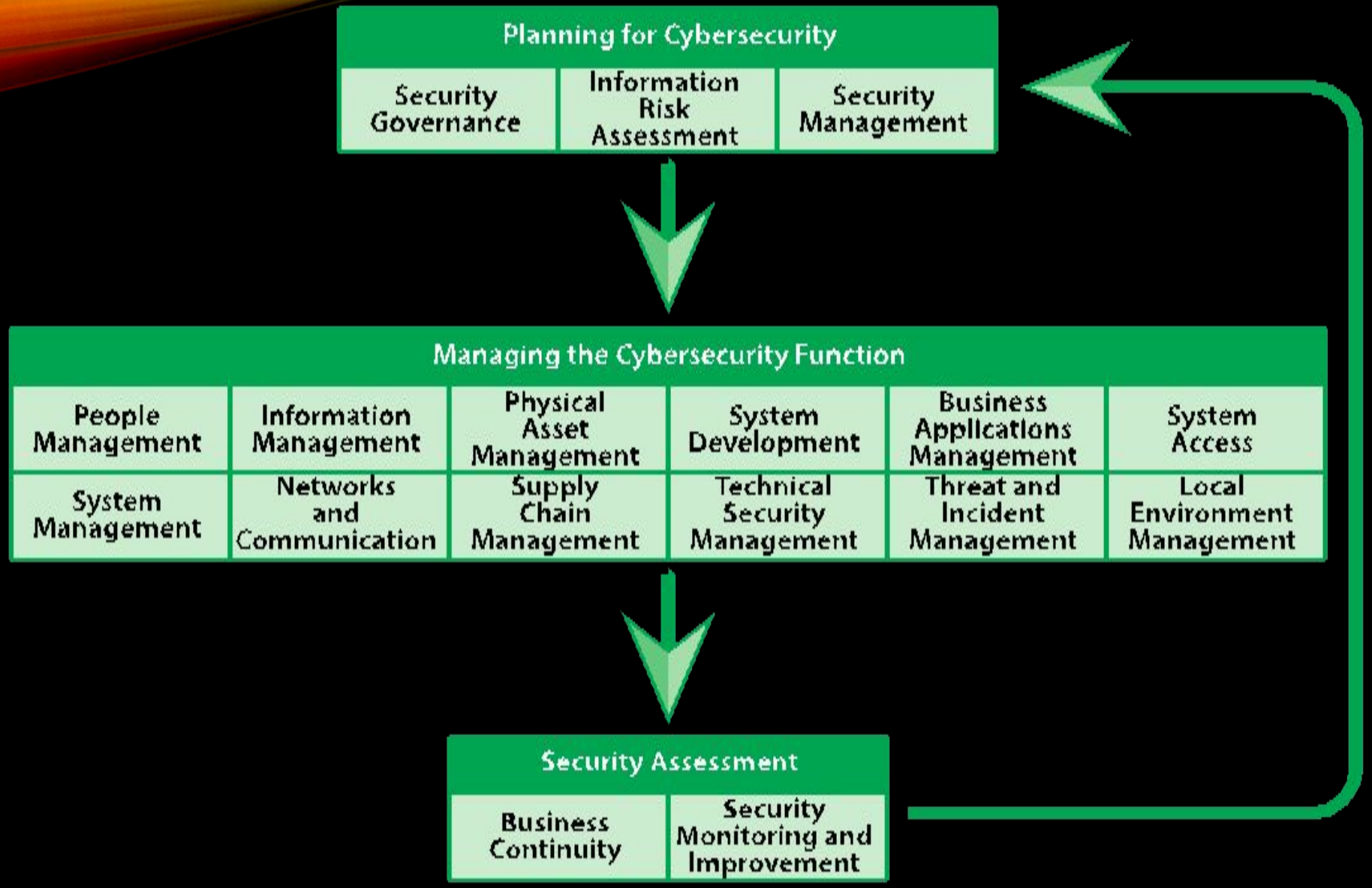


Figure 1.3 Categories in the Standard of Good Practice for Information Security

THE ISO/IEC 27000 SUITE OF INFORMATION SECURITY STANDARDS

- ISO
  - Perhaps the most important set of standards for cybersecurity
  - Is an international agency for the development of standards on a wide range of subjects
  - Founded in 1946
  - It is a voluntary, nontreaty organization whose members are designated standards bodies of participating nations as well an nonvoting observer organizations
  - The U.S. member body is the American National Standards Institute (ANSI)
  - Has issued more than 12,000 standards in a broad range of areas
  - Its purposed is to promote the development of standardization and related activities to facilitate international exchange of goods and services and to develop cooperation in the sphere of intellectual, scientific, technological, and economic activity
  - One important area of ISO standardization deals with the Open System Interconnection (OSI) communications architecture and the standards at each layer of this architecture

THE ISO/IEC 27000 SUITE OF INFORMATION SECURITY STANDARDS

- IEC
  - International Electrotechnical Commission
  - Develops standards in a joint effort with ISO in the areas of data communications, networking, and security
  - Primarily concerned with electrical and electronic engineering standards
  - In the area of information technology the IEC emphasis is on hardware and the ISO emphasis is on software
  - In 1997 the two groups formed the Joint Technical Committee 1 (JTC 1)
    - This committee has the responsibility of developing the documents that ultimately become ISO (and IEC) standards in the area of information technology

THE ISO/IEC 27000 SUITE OF INFORMATION SECURITY STANDARDS

- The ISO and IEC have developed a growing family of standards in the ISO/IEC 27000 series that deal with ISMSs

Information security management system:

consists of the policies, procedures, guidelines, and associated resources and activities, collectively managed by an organization, in the pursuit of protecting its information assets.

An ISMS is a systematic approach for establishing, implementing, operating, monitoring, reviewing, maintaining and improving an organization's information security to achieve business objectives.

It is based upon a risk assessment and the organization's risk acceptance levels designed to effectively treat and manage risks.

ISMS overview and vocabulary	ISMS requirements		ISMS guidelines		ISMS sector-specific guidelines	
27000 ISMS overview	27001 ISMS requirements	27006 Audit and certification of ISMS	27002 Code of practice for IS controls	27003 ISMS implementation	27010 Intersector/ interorganizational comms	27011 Telecomms organizations
	27009 Sector-specific application		27004 ISM measurement	27005 IS risk management	27015 Financial services	27017 IS controls for cloud services
			27007 ISMS auditing	TR 27008 Auditors on IS control	27018 Protection of PII in public clouds	27019 Energy utility industry PCS
			27013 Integrated implementation of 27001/20000	27014 Governance of IS		
			TR 27016 Organizational economics	27036 IS for supplier relationships		

ISMS – Information Security Management System
PII – personally identifiable information
PCS = process control systems

Figure 1.4 ISO 27000 ISMS Family of Standards

SECURITY CONTROLS

The management, operational, and technical controls (that is, countermeasures) prescribed for an information system to protect the confidentiality, integrity, and availability of the system and its information

CERTIFICATION

The provision by an independent body of written assurance (a certificate) that the product, service, or system in question meets specific requirements; also known as third-party conformity assessment

Table 1.3

ISO 27001 Information Security Management Systems Requirements: Requirements Topics

(Table is on page 16 in the textbook)

4 Context of the organization 4.1 Understanding the organization and its context 4.2 Understanding the needs and expectations of interested parties 4.3 Determining the scope of the information security management system 4.4 Information security management system **5 Leadership** 5.1 Leadership and commitment 5.2 Policy 5.3 Organizational roles, responsibilities and authorities **6 Planning** 6.1 Actions to address risks and opportunities 6.2 Information security objectives and planning to achieve them	**7 Support** 7.1 Resources 7.2 Competence 7.3 Awareness 7.4 Communication 7.5 Documented information **8 Operation** 8.1 Operational planning and control 8.2 Information security risk assessment 8.3 Information security risk treatment **9 Performance evaluation** 9.1 Monitoring, measurement, analysis and evaluation 9.2 Internal audit 9.3 Management review **10 Improvement** 10.1 Nonconformity and corrective action 10.2 Continual improvement

TABLE 1.4

ISO 27002 Code of Practice for Information Security Controls:

Control Topics

5 Information security policies
5.1 Management direction for information security
6 Organization of information security
6.1 Internal organization
6.2 Mobile devices and teleworking
7 Human resource security
7.1 Prior to employment
7.2 During employment
7.3 Termination and change of employment
8 Asset management
8.1 Responsibility for assets
8.2 Information classification
8.3 Media handling
9 Access control
9.1 Business requirements of access control
9.2 User access management
9.3 User responsibilities
9.4 System and application access control
10 Cryptography
10.1 Cryptographic controls
11 Physical and environmental security
11.1 Secure areas
11.2 Equipment
12 Operations security
12.1 Operational procedures and responsibilities
12.2 Protection from malware
12.3 Backup
12.4 Logging and monitoring
12 Operations security
12.5 Control of operational software
12.6 Technical vulnerability management
12.7 Information systems audit considerations
13 Communications security
13.1 Network security management
13.2 Information transfer
14 System acquisition, development and maintenance
14.1 Security requirements of information systems
14.2 Security in development and support processes
14.3 Test data
15 Supplier relationships
15.1 Information security in supplier relationships
16 Information security incident management
16.1 Management of information security incidents and improvements
17 Information security aspects of business continuity management
17.1 Information security continuity
17.2 Redundancies
18 Compliance
18.1 Compliance with legal and contractual requirements
18.2 Information security reviews

(Table is on pages 17-18 in the textbook)

Table 1.5

Mapping ISO 27001 to the ISF Standard of Good Practice

ISO 27001 Topic	ISG SGP Category
4.1 Understanding the Organization and Its Context	Security Governance
4.2 Understanding the Needs and Expectations of Interested Parties	Security Governance
4.3 Determining the Scope of the Information Security Management System	Security Management
4.4 Information Security Management System	Security Management
5.1 Leadership and Commitment	Security Governance
5.2 Policy Security Management	Security Management
5.3 Organizational Roles, Responsibilities and Authorities	Security Governance
6.1 Actions to Address Risks and Opportunities	Information Risk Assessment
6.2 Information Security Objectives and Planning to Achieve Them	Security Management
7.1 Resources	Security Management
7.2 Competence	People Management
7.3 Awareness	People Management
7.4 Communication	People Management
7.5 Documented Information	Security Management
8.1 Operational Planning and Control	Security Management
8.2 Information Security Risk Assessment	Information Risk Assessment
8.3 Information Security Risk Treatment	Information Risk Assessment
9.1 Monitoring, Measurement, Analysis and Evaluation	Security Monitoring and Improvemen
9.2 Internal Audit	Security Monitoring and Improvemen
9.3 Management Review	Security Monitoring and Improvemen
10.1 Non-conformity and Corrective Action	Security Monitoring and Improvemen
10.2 Continual Improvement	Security Monitoring and Improvemen

(Table is on pages 18-19 in the textbook)

ISO 27001 Topic	ISG SGP Category
5.1 Management Direction for Information Security	Security Monitoring and Improvement
6.1 Internal Organization	Security Governance
6.2 Mobile Devices and Teleworking	People Management
7.1 Prior to Employment	People Management
7.2 During Employment	People Management
7.3 Termination and Change of Employment	People Management
8.1 Responsibility for Assets	Physical Asset Management
8.2 Information Classification	Physical Asset Management
8.3 Media Handling	Physical Asset Management
9.1 Business Requirements of Access Control	System Access
9.2 User Access Management	System Access
9.3 User Responsibilities	System Access
9.4 System and Application Access Control	System Access
10.1 Cryptographic Controls	Technical Security Management
11.1 Secure Areas	Local Environment Management
11.2 Equipment	Local Environment Management
12.1 Operational Procedures and Responsibilities	System Development
12.2 Protection from Malware	Technical Security Management
12.3 Backup	System Management
12.4 Logging and Monitoring	Threat and Incident Management
12.5 Control of Operational Software	System Development
12.6 Technical Vulnerability Management	System Development
12.7 Information Systems Audit Considerations	Security Monitoring and Improvement
13.1 Network Security Management	Networks and Communications
13.2 Information Transfer	Networks and Communications
14.1 Security Requirements of Information Systems	Security Management
14.2 Security in Development and Support Processes	System Development
14.3 Test Data	System Development
15.1 Information Security in Supplier Relationships	Supply Chain Management
16.1 Management of Information Security Incidents and Improvements	Threat and Incident Management
17.1 Information Security Continuity	Business Continuity
17.2 Redundancies	Business Continuity
18.1 Compliance with Legal and Contractual Requirements	Security Management
18.2 Information Security Reviews	Security Monitoring and Improvement

Table 1.6

Mapping ISO 27002 to the ISF Standard of Good Practice

(Table is on pages 19-20 in the textbook)

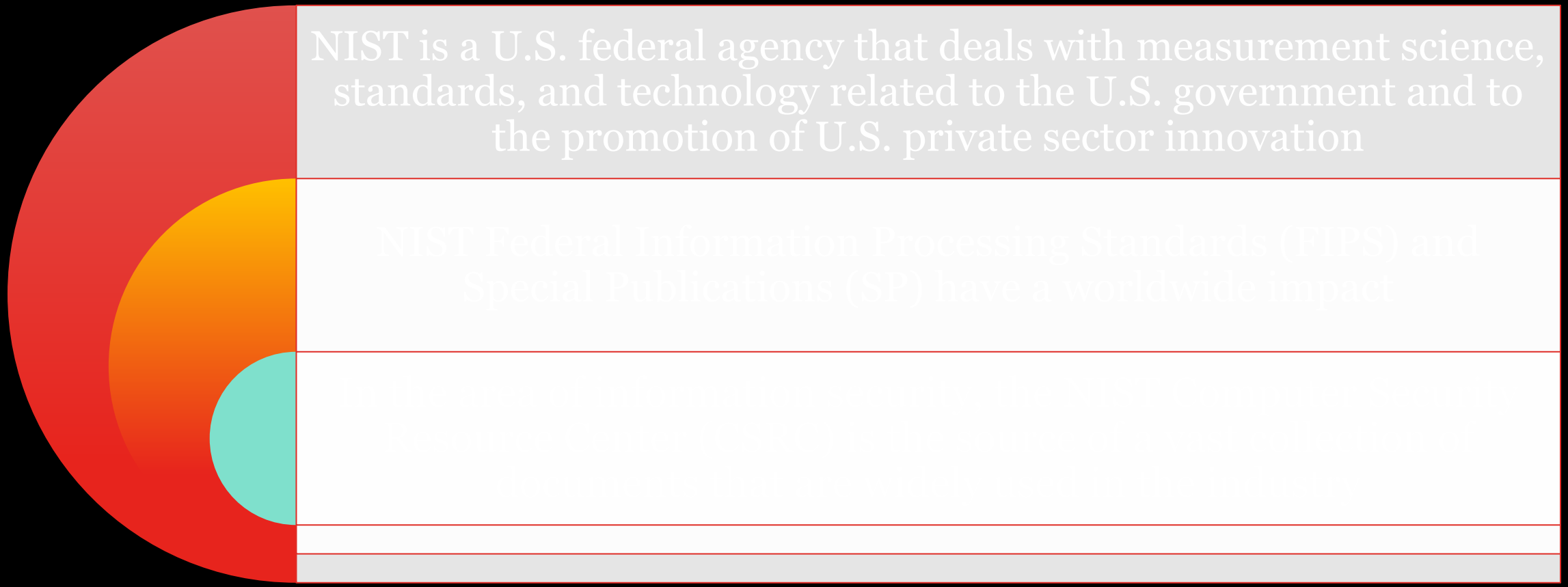
Table 1.7
Breakdown of The SGP Threat and Incident Management Category

Area	Topic	Num ber of subtopics	Type
Cyber security resilience	Technical vulnerability management	10	F
	Security event logging	7	F
	Security event management	11	S
	Threat intelligence	10	S
	Cyber attack protection	8	S
Security incident m anagem ent	Security incident management framework	7	F
	Security incident management process	5	F
	Emergency fixes	7	F
	Forensic investigations	9	S

F = fundamental topic
S = specialized topic

(Table is on page 21 in the textbook)

NIST CYBERSECURITY FRAMEWORK AND SECURITY DOCUMENTS



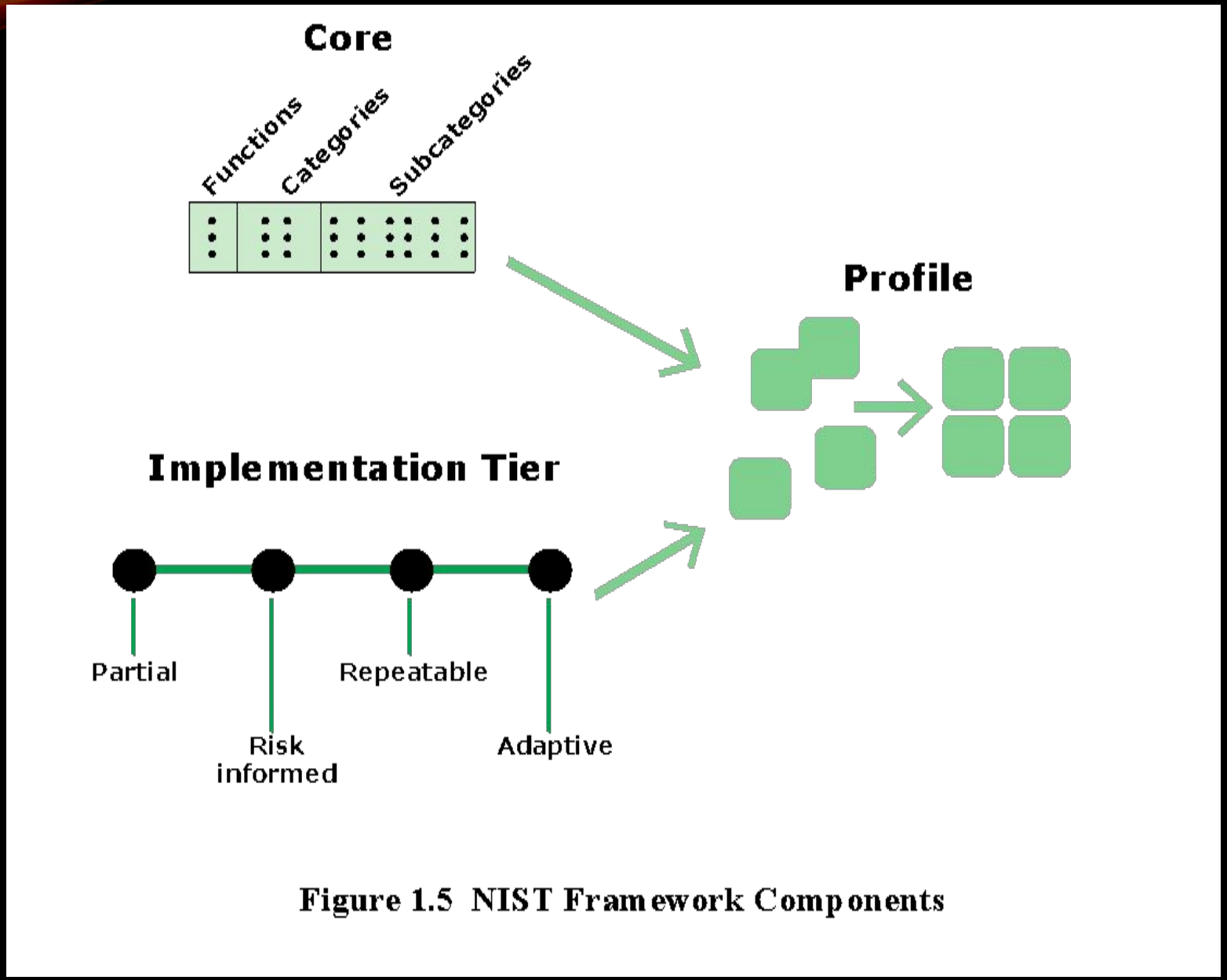


Figure 1.5 NIST Framework Components

Function	Description	Category
Identify	Develop the organizational understanding to manage cybersecurity risk to systems, assets, data, and capabilities.	Asset Management
		Business Environment
		Governance
		Risk Assessment
		Risk Management Strategy
		Supply Chain Risk Management
Protect	Develop and implement the appropriate safeguards to ensure delivery of critical infrastructure services.	Access Control
		Awareness and Training
		Data Security
		Information Protection Processes and Procedures
		Maintenance
		Protective Technology
Detect	Develop and implement the appropriate activities to identify the occurrence of a cybersecurity event.	Anomalies and Events
		Security Continuous Monitoring
		Detection Processes
Respond	Develop and implement the appropriate activities to take action regarding a detected cybersecurity event.	Response Planning
		Communications
		Analysis
		Mitigation
		Improvements
Recover	Develop and implement the appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity event.	Recovery Planning
		Improvements
		Communications

Table 1.8

NIST Cybersecurity Framework Functions and Categories

(Table is on page 23 in the textbook)

Risk Management Process	Integrated Risk Management Program	External Participation
Tier 1: Partial		
RM practices not formalized, ad hoc. Prioritization of cybersecurity activities may not be directly informed by organizational risk objectives, the threat environment, or business/mission requirements.	Limited awareness of risk, no organization-wide approach to RM. cybersecurity information to be shared within the organization.	Lack of coordination and collaboration with other entities.
Tier 2: Risk Informed		
RM practices approved by management by not established as organizational-wide policy. Informed prioritization of cybersecurity activities.	Risk-informed, processes and procedures are defined and implemented, and staff has adequate resources to perform their cybersecurity duties. No organization-wide approach to RM.	No formal coordination and collaboration with other entities.
Tier 3: Repeatable		
RM practices are formally approved and expressed as policy. Organizational cybersecurity practices are regularly updated based on changes in business/mission requirements and the threat and technology landscape.	Organization-wide approach to RM. Risk-informed policies, processes, and procedures are defined, implemented as intended, and reviewed. Personnel possess the knowledge and skills to perform their appointed roles and responsibilities.	Collaboration with partners enables RM decisions in response to external events.
Tier 4: Adaptive		
Organization actively adapts to a changing cybersecurity landscape and responds to evolving and sophisticated threats in a timely manner.	Organization-wide approach to managing cybersecurity risk that uses risk-informed policies, processes, and procedures to address potential cybersecurity events.	Organization manages risk and actively shares information with partners to ensure that accurate, current information is being distributed and consumed.

Table 1.9

Cybersecurity Framework Implementation Tiers

(Table is on page 24-25 in the textbook)

COUNTERMEASURE

An action, a device, a procedure, or a technique that reduces a threat, a vulnerability, or an attack by eliminating or preventing it, by minimizing the harm it can cause, or by discovering and reporting it so that corrective action can be taken

NIST SECURITY DOCUMENTS

- SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations* is by far the most significant document
- This document lists management, operational, and technical safeguards or countermeasures prescribed for an information system to protect the confidentiality, integrity, and availability of the system and its information
- Although intended for U.S. government systems, it is of equal applicability to IT systems in any organization
- State-of-the-practice security controls and control enhancements have been integrated into the latest revision (2013) to address the evolving technology and threat space
- The revision also features eight new families of privacy controls that are based on the internationally accepted fair information practice principles

Other documents of special interest include:

- **FIPS 200, *Minimum Security Requirements for Federal Information and Information Systems* (2006):** Specifies minimum security requirements in 17 security-related areas with regard to protecting the confidentiality, integrity, and availability of federal information systems and the information processed, stored, and transmitted by those systems.

- **SP 800-100, *Information Security Handbook: A Guide for Managers* (2006):** Provides a broad overview of information security program elements to assist managers in understanding how to establish and implement an information security program. Its topical coverage overlaps considerably with ISO 27002.

- **SP 800-55, *Performance Measurement Guide for Information Security* (2008):** Provides guidance on how an organization, through the use of metrics, identifies the adequacy of in-place security controls, policies, and procedures.

- **SP 800-27, *Engineering Principles for Information Technology Security: A Baseline for Achieving Security* (2004):** Presents a list of system-level security principles to be considered in the design, development, and operation of an information system.

- **SP 800-12, *Introduction to Information Security*, (2017):** Provides an outstanding introduction to the topic of information security.

- **SP 800-144, *Guidelines on Security and Privacy in Public Cloud Computing*:** Addresses the important security/privacy issues involved in moving data and applications to the cloud.

ATTACK

Any kind of malicious activity that attempts to collect, disrupt, deny, degrade, or destroy information system resources or the information itself

THE CIS CRITICAL SECURITY CONTROLS FOR EFFECTIVE CYBER DEFENSE

- The Center for Internet Security (CIS) is a nonprofit community of organizations and individuals seeking actionable security resources
- The CIS identifies specific security techniques and practices that the CIS group of experts agree are important
- A major contribution of CIS is The CIS Critical Security Controls for Effective Cyber Defense (CSC)
  - CSC focuses on the most fundamental and valuable actions that every enterprise should take
  - CSC is not simply a list of controls that might be useful but a source that can be used to guide implementation of policy
  - Controls listed in the CSC are designed to be the most effective and specific technical measures available to detect, prevent, respond to, and mitigate damage from the most common to the most advanced attacks

Basic	Foundational	Organizational
CSC 1: Inventory and Control of Hardware Assets **CSC 2**: and Control of Hardware Assets **CSC 3**: Continuous Vulnerability Management **CSC 4**: Controlled Use of Administrative Privileges **CSC 5**: Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers **CSC 6**: Maintenance, Monitoring, and Analysis of Audit Logs	**CSC 7**: Email and Web Browser Protections **CSC 8**: Malware Defenses **CSC 9**: Limitation and Control of Network Ports, Protocols, and Services **CSC 10**: Data Recovery Capability **CSC 11**: Secure Configuration for Network Devices such as Firewalls, Routers, and Switches **CSC 12**: Boundary Defense **CSC 13**: Data Protection **CSC 14**: Controlled Access Based on the Need to Know **CSC 15**: Wireless Access Control **CSC 16**: Account Monitoring and Control	**CSC 17**: Implement a Security Awareness and Training Program **CSC 18**: Application Software Security **CSC 19**: Incident Response and Management **CSC 20**: Penetration Tests and Red Team Exercises

Table 1.10

The CIS Critical Security Controls List of Controls for Effective Cyber Defense

CRITICAL SECURITY CONTROLS

- Each control section includes the following:
  - A description of the importance of the control in blocking or identifying the presence of attacks and an explanation of how attackers actively exploit the absence of this control
  - A chart of the specific actions, called sub-controls, that organizations are taking to implement, automate, and measure the effectiveness of this control
  - Procedures and tools that enable implementation and automation
  - Sample entity relationship diagrams that show components of implementation

COBIT 5 FOR INFORMATION SECURITY

Control Objectives for Business and Related Technology (COBIT) is a set of documents published by ISACA

ISACA is an independent, nonprofit, global association engaged in the development, adoption, and use of globally accepted, industry-leading knowledge and practices for information systems

COBIT 5 is the fifth version of the set of documents to be released and is intended to be a comprehensive framework for the governance and management of enterprise IT

Policy	Scope for the Information Security Function
Business continuity and disaster recovery	• Business impact analysis (BIA) • Business contingency plans with trusted recovery • Recovery requirements for critical systems • Defined thresholds and triggers for contingencies, escalation of incidents • Disaster recovery plan (DRP) • Training and testing
Asset management	• Data classification • Data ownership • System classification and ownership • Resource utilization and prioritization • Asset life cycle management • Asset protection measures
Rules of behavior (acceptable use)	• At-work acceptable use and behavior: • Off-site acceptable use and behavior:
Information systems acquisition, software development and maintenance	• Information security in the life cycle process • Information security requirements definition process • Information security within the procurement/acquisition process • Secure coding practices • Integration of information security with change management and configuration management
Vendor management	• Contract management: – Information security terms and conditions – Information security evaluation – Monitoring of contracts for information security compliance
Communication and operation management	• IT information security architecture and application design: • SLA: • IT information security operational procedures
Compliance	• IT information security compliance assessment process: • Development of metrics • Assessment repositories:
Risk management	• Organizational risk management plan: • Information risk profile

Table 1.11

COBIT 5 for Information Security: Main Policies and Functions

(Table is on pages 29-30 in the textbook)

COBIT 5 also provides a useful organization of the techniques used to achieve effective security into 5 domains and 37 processes, under two general categories:

- Governance of Enterprise IT
  - Evaluate, Direct and Monitor (EDM): 5 processes
- Management of Enterprise IT
  - Align, Plan and Organize (APO): 13 processes
  - Build, Acquire and Implement (BAI): 10 processes
  - Deliver, Service and Support (DSS): 6 processes
  - Monitor, Evaluate and Assess (MEA): 3 processes

PAYMENT CARD INDUSTRY DATA SECURITY STANDARD (PCI DSS)

- The PCI-DSS, a standard of the PCI Security Standards Council, provides guidance for maintaining payment security
- The standard sets the technical and operational requirements for organizations accepting or processing payment transactions and for software developers and manufacturers of applications and devices used in those transactions
- PCI DSS compliance governs the way payment card data is processed, handled, and stored
- It is required for merchants and all businesses that touch payment data in any way

The PCI defines the scope of the PCI DSS as follows:

The PCI DSS security requirements apply to all system components included in or connected to the cardholder data environment. The cardholder data environment (CDE) is comprised of people, processes and technologies that store, process, or transmit cardholder data or sensitive authentication data. “System components” include network devices, servers, computing devices, and applications.

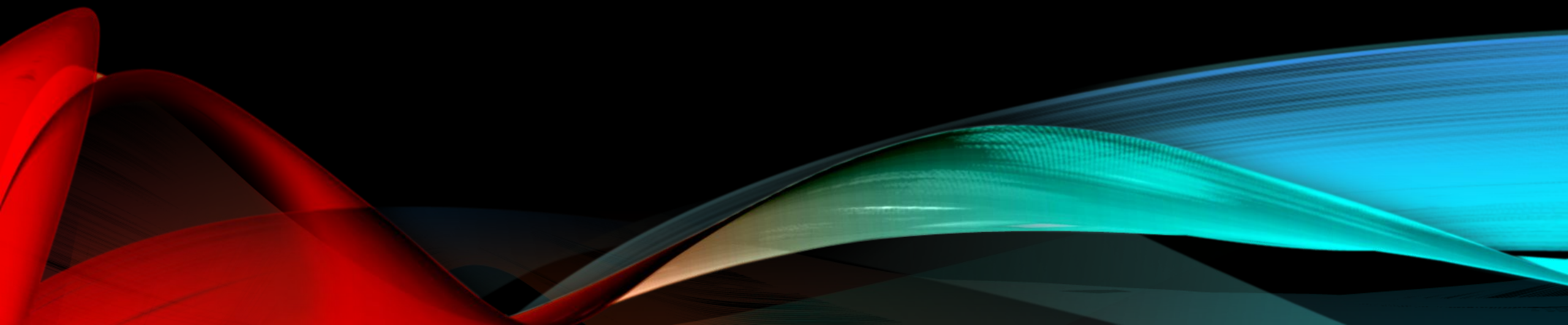


Table 1.12

PCI DSS Requirements

Goals	PCI-DSS Requirements
Build and Maintain a Secure Network and Systems	**1.** Install and maintain a firewall configuration to protect cardholder data **2.** Do not use vendor-supplied defaults for system passwords and other security parameters
Protect Cardholder Data	**3.** Protect stored cardholder data **4.** Encrypt transmission of cardholder data across open, public networks
Maintain a Vulnerability Management Program	**5.** Protect all systems against malware and regularly update anti-virus software or programs **6.** Develop and maintain secure systems and applications
Implement Strong Access Control Measures	**7.** Restrict access to cardholder data by business need to know **8.** Identify and authenticate access to system components **9.** Restrict physical access to cardholder data
Regularly Monitor and Test Networks	**10.** Track and monitor all access to network resources and cardholder data **11.** Regularly test security systems and processes
Maintain an Information Security Policy	**12.** Maintain a policy that addresses information security for all personnel

(Table is on page 31 in the textbook)

ITU-T SECURITY DOCUMENTS

- The International Telecommunication Union (ITU) is a United Nations specialized agency
- The members of ITU-T are governments
- The U.S. representation is housed in the Department of State
- The ITU's charter states that it is "responsible for studying technical, operating, and tariff questions and issuing Recommendations on them with a view to standardizing telecommunications on a worldwide basis"
- Its primary objective is to standardize, to the extent necessary, techniques and operations in telecommunications to achieve end-to-end compatibility of international telecommunication connections, regardless of the countries of origin and destination

Table 1.13

Key Topics by ITU-T Security Recommendations

Topic	Subtopics
Security requirements	Threats, risks and vulnerabilities Personnel and physical security requirements Next Generation Networks Security requirements for IPCablecom IPTV
Security architectures	Open systems security architecture Security services Security architecture for end-to-end communications Availability of the network and its components Application-specific architectures Peer-to-peer security architectures Message security Network management architecture IPCablecom architecture IPTV
Security management	Information security management Risk management Incident handling Asset management Governance of information security Telecommunications management
Role of the directory	Directory concepts Public-key security mechanisms Privilege management infrastructure Protection of Directory information Privacy protection
Identity management and telebiometrics	Identity management Overview of identity management Key ITU-T identity management standards Telebiometrics Telebiometric authentication Security and safety aspects of telebiometrics Telebiometrics related to human physiology Telebiometrics in e-health and telemedicine
Examples of approaches to authentication and non-repudiation	Secure password-based authentication protocol with key exchange One-time password authentication Non-repudiation framework based on one-time password Delegated non-repudiation

(continued)

Securing the network infrastructure	The telecommunications management network Securing monitoring and control activities Securing network operation activities and management applications Protection against electromagnetic threats Common security management services CORBA-based security services
Some specific approaches to network security	Next Generation Network (NGN) security Mobile communications security Security for home networks IPCablecom Ubiquitous Sensor Networks
Cybersecurity and incident response	Cybersecurity information exchange Exchange of vulnerability information Discovery of cybersecurity information Incident handling
Application security	Voice over IP (VoIP) and multimedia IPTV DRM for Cable Television Multiscreen Secure fax Web services Tag-based services
Countering common network threats	Spam Malicious code, spyware and deceptive software Notification and dissemination of software updates
Security aspects of cloud computing	Key characteristics of cloud computing Generic cloud computing capabilities and services. Emerging cloud services A security framework for cloud computing Security threats and security challenges to cloud computing

Table 1.13

Key Topics by ITU-T Security Recommendations

(Table is on pages 32-34 in the textbook)

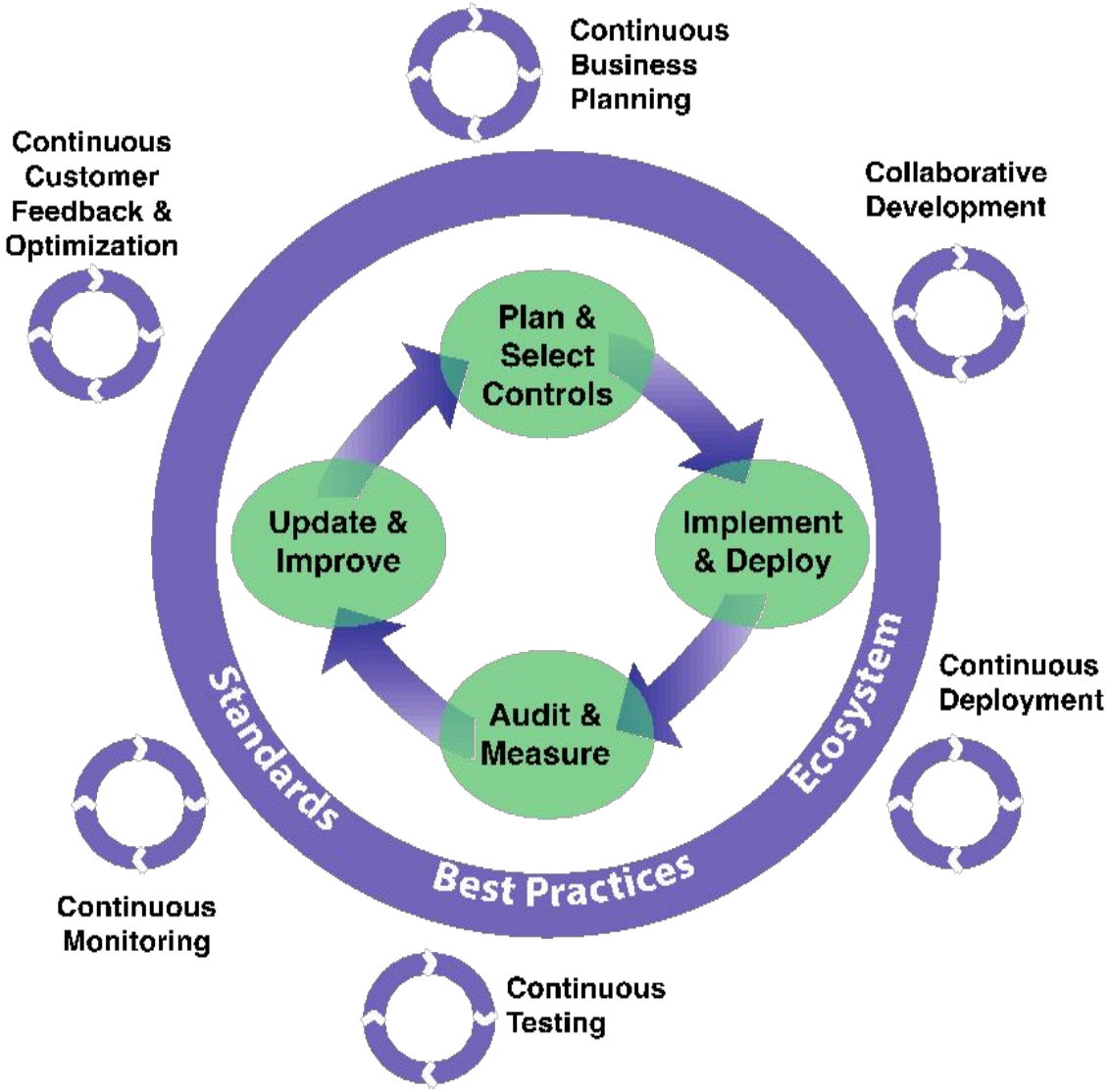


Figure 1.6 Cybersecurity Management Process



Figure 1.7 Cybersecurity Information and Decision Flows within an Organization

SUMMARY

- The need for standards and best practices documents in cybersecurity
- Standard of Good Practice for Information Security
- Differences between ISO 27001 and ISO 27002
- The role of the National Institute of Standards and Technology (NIST) Cybersecurity Framework and how it differs from the objectives of ISO 27002
- The value of the Center for Internet Security (CIS) Critical Security Controls